powertec

UTILITIES | CRITICAL INFRASTRUCTURE | TRAINING

SECURITY DESIGN SPECIFICATION

Cybersecurity and Information Assurance Programme

Security architecture, risk treatment and incident response for the Powertec Isolation & Document Control and Training platforms.

- Enterprise Security Architecture
- Information Protection
- Operational Resilience
- Risk Management
- Incident Response & Recovery

Prepared for client technical review

Engineering, security and compliance stakeholders

Version 3.0 · October 2026

COMMERCIAL IN CONFIDENCE

DOCUMENT STRUCTURE

Contents

Select any entry to go to that section. Every page carries a Back to contents link.

—	**ASSURANCE SUMMARY**	03 ›
01	**SCOPE & THREAT BASIS**	05 ›
1	Scope and design boundaries	06 ›
2	Threat landscape and design response	07 ›
3	Information classification and data ownership	08 ›
02	**SECURITY ARCHITECTURE**	09 ›
4	Target architecture and trust boundaries	10 ›
5	Multi-organisation and multi-site isolation	12 ›
6	Safety-document integrity and lock custody	14 ›
7	Training platform security	15 ›
03	**SECURITY TECHNOLOGY**	16 ›
8	Hosting, data residency and required services	17 ›
04	**RISK & ASSURANCE**	20 ›
9	Risk methodology and register	21 ›
10	Security requirements and acceptance evidence	25 ›
05	**INCIDENT RESPONSE & RECOVERY**	27 ›
11	Incident severity, detection and response	28 ›
12	Incident management operating procedure	29 ›
13	Worst-case scenario playbooks	30 ›
14	Recovery objectives and business continuity	34 ›
06	**GOVERNANCE, COMPLIANCE & DELIVERY**	35 ›
15	Legal, contractual and standards obligations	36 ›
16	Delivery programme	37 ›
17	Governance and operating cadence	39 ›
18	Supplier and subcontractor controls	40 ›
19	Client assurance pack	41 ›
20	Go-live acceptance gates	42 ›
21	Standards and reference sources	43 ›

DOCUMENT CONTROL

Version
3.0
Issued
October 2026
Type
Security design specification for client assessment
Covers
Isolation & Document Control · Powertec Training · Multi-client site deployments

LABEL KEY

DESIGN CONTROL
Security control specified in the design.

VERIFIED AT ACCEPTANCE
Proven by test and evidence before go-live.

SERVICE TARGET
Operational level contracted with the client.

EXECUTIVE SUMMARY

Assurance summary

Powertec will supply two separately governed platforms for data centre electrical operations: **(A) Isolation & Document Control** — single-line diagrams, apparatus and lock registers, key custody and PTW / SFT / LOA workflows; and **(B) Powertec Training** — course content, assessments, certificates and competence records. This specification defines how client engineering information, safety-document records and personnel data are protected, segregated and independently verified.

Data stays in Sweden

Hosted in Azure Sweden Central, whose datacentres are in Gävle, Sandviken and Staffanstorp, or in another region the client approves. Zone-redundant replication remains in-country.

Your identity provider, your control

Users sign in through the client's own Entra ID. When the client disables a user, platform access ends. Privileged roles require phishing-resistant MFA.

No shared data between organisations

Every record carries organisation and site identifiers, enforced at both API and database. High-sensitivity asset-owner information defaults to a dedicated environment.

Site safety rules stay in charge

The application records isolations; it has no interface to switchgear, SCADA or EPMS. Loss of verification shows "status unverified", never "safe".

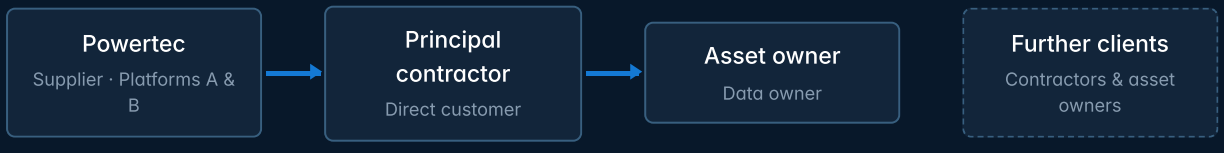
Tamper-evident record

Every critical action is written with user identity and UTC timestamp to an append-only archive that platform administrators cannot alter.

Proven before go-live

Independent penetration test, OWASP ASVS 5.0 verification, restore test and a 24/7 incident drill precede written client acceptance.

CONTRACTING AND DATA-OWNERSHIP CHAIN — INITIAL DEPLOYMENT



EXECUTIVE SUMMARY

Design decisions

The principal security decisions and the condition under which each is accepted by the client.

DECISION	DESIGN / ACCEPTANCE CONDITION
Data onboarding	No client engineering drawings are loaded until data-owner permission, processing authority, hosting location, security design and retention are approved in writing.
Identity	Federation with each customer's identity provider (Entra ID by default); phishing-resistant MFA (FIDO2 / passkeys) for privileged users.
Isolation	Organisation + site + document-level authorisation, enforced by server-side policy and backed by database row-level security.
High-sensitivity customers	Dedicated Azure subscription / resource group or separate tenant and data plane where the contract requires.
Operational integrity	Server-side workflow state machines, approvals, two-person control for critical actions, immutable audit export.
Hosting	Azure in a client-approved region (Sweden Central for Swedish sites), private endpoints for data services, managed WAF, monitored logs.
Assurance	OWASP ASVS 5.0 traceability, independent testing, client acceptance and periodic reassessment.
Recovery	Documented degraded-mode procedure under site rules; electronic records are never treated as proof of physical isolation.

ACCEPTANCE PRINCIPLE Each control in this specification carries a defined acceptance test (Section 10). Production use of client data begins only after the client's written deployment authorisation (Section 20).

01

PART 01

SCOPE & THREAT BASIS

What the platforms cover, the boundaries that keep electrical safety decisions with the site, the threats the design is built against, and how client information is classified and owned.

1	Scope and design boundaries
2	Threat landscape and design response
3	Information classification and data ownership

SECTION 01

Scope and design boundaries

PLATFORM A · ISOLATION & DOCUMENT CONTROL

Single-line diagrams (SLDs), apparatus and isolation-point registers, lock, key and box custody, PTW / SFT / LOA workflows, approvals and audit.

PLATFORM B · POWERTEC TRAINING

Course content, assessments, results, certificates and competence records, with a signed competence interface to Platform A.

Also in scope: APIs and web / PWA clients, user directories, administration, support access, backups, third-party integrations and development tooling.

RECORDS, NEVER OPERATES

Neither platform has any interface to switchgear, SCADA, EPMS or BMS. A lock-tracker entry, green status or electronic permit is never evidence that plant is isolated, proved dead or earthed. Physical procedures and the site's authorisation regime remain controlling.

RETAINED BY THE CLIENT

Electrical safety rules, lockout practice, approval of operational switching and appointment of SAP / AP / CP personnel.

AGREED WITH EACH CLIENT AT ONBOARDING

Data ownership and processing roles, classification, identity integration, cloud tenancy and residency, offline access policy, site safety rules, notification obligations and retention schedules.

Two deployment tiers

TIER 1 · STANDARD SAAS

Strict logical tenant segregation for routine clients.

TIER 2 · DEDICATED / CLIENT-HOSTED

Restricted data, sensitive SLDs, or clients that prohibit external hosting. Same secure code; no shared data.

SECTION 02

Threat landscape and design response

A hyperscale data centre's SLDs and lock mappings are high-value reconnaissance material, and permit state is safety-relevant. The design therefore prioritises **confidentiality of engineering drawings**, **integrity of permit and custody records**, and **fail-safe behaviour** when the system cannot verify its own state.

HOW BREACHES OCCUR — VERIZON 2025 DATA BREACH INVESTIGATIONS REPORT

ATTACK PATTERN	SHARE OF BREACHES	DESIGN RESPONSE IN THESE PLATFORMS
Third-party involvement	30% doubled year on year	Supplier register with data-flow and exit terms; no third-party scripts, fonts or analytics on engineering pages; integrations scoped to least privilege; client supplier-assurance requirements flowed down contractually.
Credential abuse (initial vector)	22%	No local passwords — sign-in via the client's Entra ID with conditional access; phishing-resistant MFA for privileged roles; session revocation on account removal.
Exploitation of vulnerabilities (initial vector)	20% up 34%	WAF at the edge; databases and storage on private endpoints only; SAST, dependency and secret scanning block merges; patch SLAs by severity; independent penetration test before go-live.
Ransomware present	44% up 37%	Immutable backups under separate administration; point-in-time restore; quarterly restore tests; manual site procedure takes over without data loss.

THREAT ACTORS DESIGNED AGAINST

- External attackers
- Compromised contractor accounts
- Accidental AP / SAP / CP error
- Malicious insiders
- Compromised CI/CD or dependencies
- Cloud provider incidents
- Misconfigured administrators

SECTION 03

Information classification and data ownership

INFORMATION	CLASSIFICATION	PROTECTION / APPROVAL
Demonstration and marketing material	PUBLIC · SYNTHETIC	Synthetic data only: no real drawings, names, contacts, project identifiers or credentials.
Generic training lessons	INTERNAL / LICENSABLE	Copyright and entitlement controls; approval before cross-client reuse.
Employee names, numbers, training results	CONFIDENTIAL PERSONAL	Privacy notice, purpose limitation, minimisation, retention and access rights.
Client SLDs, layouts, apparatus identifiers	RESTRICTED · ENGINEERING	Explicit written data-owner authorisation; approved storage; no public links.
Live PTW / SFT / LOA, key custody, work locations	RESTRICTED · OPERATIONAL	Site-scoped access; audit, integrity, retention and emergency procedure.
Credentials, API tokens, signing keys	SECRETS	HSM-backed key vault; never in browser, repository or support screenshots.
Security events and investigation material	RESTRICTED · SECURITY	Need-to-know access, retention and evidence preservation.

Ownership model

DATA-OWNER AUTHORITY

The originating asset owner decides whether engineering drawings may be processed. A contractor's position as contracting customer does not by itself authorise storage of the asset owner's drawings.

CONTRACTUAL DEFINITION

Contracts define authorised purpose, controller / processor roles, subprocessor approval, data location, export, deletion and breach notification.

TRAINING CONTENT

Training content derived from a client's procedures is held in that client's tenant and licensed separately from Powertec's generic library.

02

PART 02

SECURITY ARCHITECTURE

How confidential engineering information is protected, access is controlled and operational integrity is maintained across multiple client environments and both platforms.

4	Target architecture and trust boundaries
5	Multi-organisation and multi-site isolation
6	Safety-document integrity and lock custody
7	Training platform security

SECTION 04

Target architecture and trust boundaries



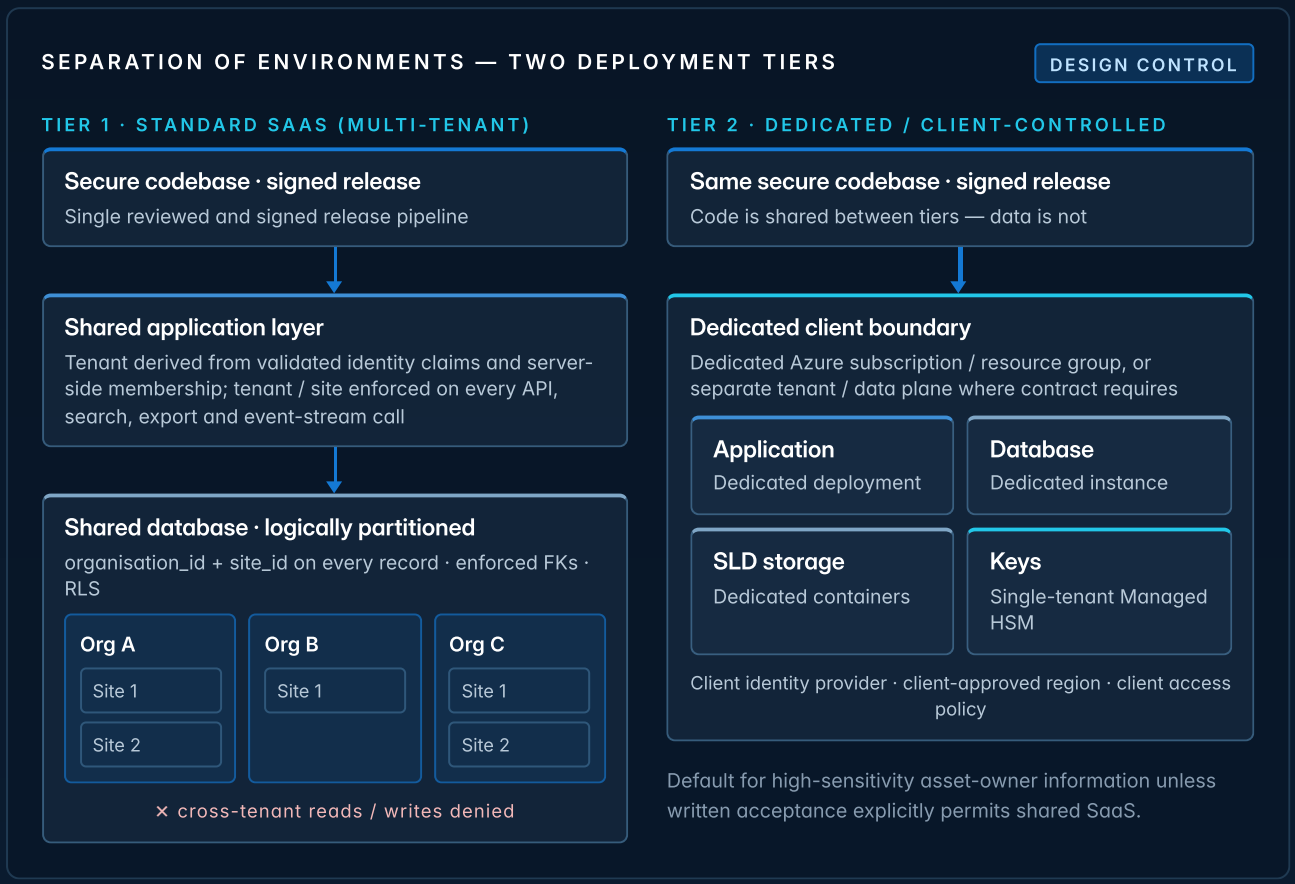
Layer design and controls

Six trust boundaries (A–F) separate the layers shown in the architecture diagram. Every crossing is authenticated, authorised and logged.

LAYER	DESIGN AND CONTROLS
User device	Managed-device policy where required; secure browser, no shared devices, session timeout, conditional access, no sensitive offline caches.
Identity	Entra ID B2B / OIDC; federated SSO per organisation; MFA; SCIM or controlled JIT provisioning; periodic access reviews.
Edge	Azure Front Door Premium with WAF managed rules; TLS 1.2+ (1.3 preferred); DDoS protection; bot and rate limiting; custom domain.
Application	Azure App Service / Container Apps with managed identity; private data access; hardened runtime; separate prod / stage / dev.
API	Central authorisation middleware; schema validation; CSRF controls; idempotency keys; tenant / site enforcement on every call.
Database	Azure Database for PostgreSQL Flexible Server; tenant / site FK constraints; row-level security as defence-in-depth; zone-redundant HA; PITR.
SLD storage	Private Azure Blob Storage; customer / site-scoped object keys; server-mediated access; malware scanning; watermark / export controls.
Secrets	Azure Key Vault (HSM-backed), managed identities, key rotation, break-glass custody and access audit.
Logging	Azure Monitor / Log Analytics and Sentinel (or client SIEM); append-only evidence archive with immutable retention.
Training	Separate app and database; only signed competence assertions cross to the isolation app; no shared administration.
DevOps	Private GitHub repos, branch protection, CODEOWNERS, OIDC CI/CD, signed releases, SAST / SCA / secret scanning.
Recovery	Encrypted backups, tested restores, region and failure-mode policy per client; independent audit retention.

SECTION 05

Multi-organisation and multi-site isolation



ISOLATION REQUIREMENTS

- Tenant identifiers derive from validated identity claims and server-side membership, never from user-submitted JSON or a URL parameter.
- Every record (drawings, locks, keys, PTWs, training results, comments, exports, search indexes, attachments, audit events) carries `organisation_id` and `site_id` with enforced foreign keys and consistent policy.
- API and database deny cross-tenant reads and writes, including object- and field-level authorisation, search, pagination, exports, SSE / websocket messages, cached results and background jobs.
- Cross-client support uses time-limited, approved, logged privileged elevation. Powertec staff have no standing read access to customer drawings.

Tier comparison

ATTRIBUTE	TIER 1 · STANDARD SAAS	TIER 2 · DEDICATED / CLIENT-HOSTED
Intended use	Routine clients	Restricted data, sensitive SLDs, clients prohibiting external hosting; default for high-sensitivity asset-owner information
Boundary	Strict logical tenant segregation within shared hosting	Dedicated Azure subscription / resource group, or separate tenant / data plane where contract requires
Data stores	Shared database and storage; organisation_id + site_id with enforced FKs and RLS	Dedicated storage, databases and keys
Key management	HSM-backed Key Vault, per-tenant key scoping	Single-tenant Managed HSM; key material never leaves the deployment region
Authentication	Federated SSO via the client's identity provider	Federated SSO via the client's identity provider
Acceptance test	Automated cross-tenant negative tests (SEC-02)	Architecture review of the independent boundary and access policy (SEC-15)

Client lifecycle controls

SECURE ONBOARDING

- Data ownership and processing roles agreed
- Classification rules
- Identity federation
- Approved tenancy and data residency
- Offline access policy and site safety rules
- Notification and retention obligations

OPERATION

- Client-controlled permissions via federated identity
- Organisation-specific security policy
- Time-limited, approved, logged support elevation
- No standing Powertec access to drawings
- Annual independent assessment

SECURE OFFBOARDING

- Approved export
- Legal hold checks
- Key and account revocation
- Deletion certificates
- Backup expiry confirmation

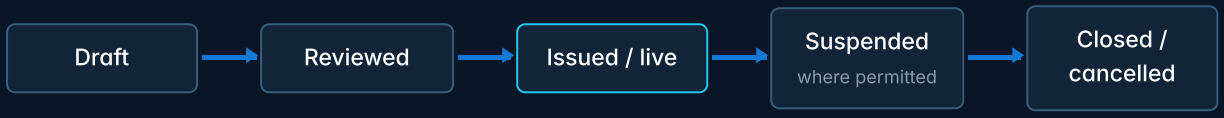
PRINCIPLE No organisation can reach another organisation's data in either tier. Cross-tenant attempts are denied at API and database layers and raise a monitored security alert (Section 11).

SECTION 06

Safety-document integrity and lock custody

PTW / SFT / LOA WORKFLOW STATE MACHINE

DESIGN CONTROL



Each transition requires a server-enforced role, prerequisites and verified actor identity · clients cannot edit status directly

Canonical records

Stable, non-reusable identifiers for organisation, site, drawing revision, apparatus, isolation point, lock, key, box, person, authorisation and safety document, with referential integrity and revision history.

Two-person control

An independent approver is required for changing approved apparatus / lock mapping, replacing an active drawing, emergency cancellation, administrator elevation and bulk import. Exact workflow is set by site rules.

Concurrency

Database transactions and unique active-allocation constraints prevent one physical key or box being assigned to incompatible simultaneous work; race conditions are tested.

Physical reconciliation

Barcode / QR is an aid, not proof. Shift or site-approved reconciliation between cabinet, physical lock / key, issued documents and digital records; any discrepancy triggers hold and escalation.

Training competence linkage

Platform B supplies signed competence status; role authorisation and current site appointment are approved separately. A completed course never confers SAP / AP / CP authority.

SLD control

Every image / PDF carries approved revision, source owner, effective date, checksum, superseded status, permitted distribution and apparatus links. An approved SLD is never silently overwritten.

Fail-safe design

Loss of network, identity provider, database or integrity verification blocks new electronic issuances unless an approved, separately documented manual process exists. The interface displays **“status unverified”**, never “safe”.

SECTION 07

Training platform security

Training records influence who may work on live systems. The training platform is therefore designed so that a compromised course, account or administrator cannot grant operational authority.

Separate platform, separate trust

Own application, database and administrator roles. The only path into Platform A is a signed competence assertion; a training administrator holds no rights in Platform A.

Signed competence assertions

Each assertion names the person, competence, issuer and expiry, and is signed with an HSM-held key. Platform A verifies the signature, then checks the independent site appointment before any role is usable.

Learner identity

Client staff sign in through their employer's Entra ID. Individual contractors without a corporate directory use Entra External ID with MFA, never shared or local accounts.

Assessment integrity

Scoring is server-side; answer keys never reach the browser. Questions are drawn from randomised pools within timed attempts. Every attempt and answer is logged.

Result changes

Assessor and moderator roles are separated. Any change to a recorded result needs a second approver and is written to the immutable audit archive.

Certificate verification

Each certificate has a unique serial and QR link to a verification page returning valid / expired / revoked. The page shows only name, competence and dates; revocation is immediate.

Content protection

Client-derived content is tagged to its tenant and licence and cannot be published to another tenant without approval. Uploaded files are malware-scanned (Defender for Storage).

Personal data

Collected: name, employer, contact, results, certificates. No special-category data and no national identity numbers. Retention per contract; data-subject requests handled within GDPR time limits.

03

PART 03

SECURITY TECHNOLOGY

The Azure-centric reference implementation: hosting and data residency, and each product with its security function and configuration criteria.

8 Hosting, data residency and required services

SECTION 08

Hosting, data residency and required services

Platform facts that underpin the design. Values are published Azure service characteristics. DESIGN CONTROL

REGION

Azure Sweden Central — datacentres in Gävle, Sandviken and Staffanstorp. Data stored in Sweden; zone-redundant replication stays in-country. The Azure EU Data Boundary, completed February 2025, keeps customer data stored and processed in the EU.

DATABASE AVAILABILITY

PostgreSQL Flexible Server, zone-redundant HA: 99.99% SLA; synchronous replication to a standby in another zone; automatic failover in 60–120 seconds with zero data loss.

DATABASE RECOVERY

Point-in-time restore across a 7–35 day retention window; transaction-log backups give an RPO of up to 5 minutes; backups encrypted with AES-256.

KEY PROTECTION

Key Vault Premium and Managed HSM run on FIPS 140-3 Level 3 validated hardware. Managed HSM is single-tenant and does not store or process data outside its region — used for the dedicated tier.

SELECTION BASIS

Products below form the reference implementation. Final selection follows the client's enterprise standards, licensing and hosting approvals; any substitute must meet the same acceptance tests.

PRODUCT / CAPABILITY	WHERE / WHY	IMPLEMENTATION AND SELECTION CRITERIA
IDENTITY AND ACCESS MANAGEMENT		
Entra ID P1/P2	Client identity boundary; federation, MFA, conditional access	Enterprise app, app roles / groups, OIDC, guest lifecycle, break-glass accounts; client licence confirmed.
Entra External ID	Individual contractor learners (Platform B)	MFA enforced; no local passwords; self-service limited to own record.
Intune / approved MDM	Managed devices and mobile posture	Compliant devices for sensitive sites; selective wipe, disk encryption, device revocation.
NETWORK SECURITY		
Azure Front Door Premium + WAF	Internet edge; attack-surface reduction	Managed rules tuned for false positives, rate limits, geo controls only if approved, TLS and alerting.
APPLICATION HOSTING		
Azure App Service or Container Apps	Hardened API runtime	Managed identity, private networking, deployment slots, health probes, autoscaling, immutable releases.
DATABASE AND DOCUMENT SECURITY		
Azure Database for PostgreSQL	Authoritative lock / document / training stores	Private endpoint, encryption, zone-redundant HA, PITR, row / tenant constraints, transactional outbox, separate databases by sensitivity.
Azure Blob Storage + Defender for Storage	SLDs, evidence, course files	Private containers, versioning, malware scanning, retention, short-lived access, controlled downloads.
Azure Key Vault / Managed HSM	Keys, certificates, secrets	RBAC, managed identity, rotation, purge protection, restricted administrators.
SECURITY MONITORING AND INCIDENT DETECTION		
Azure Monitor / Log Analytics	Telemetry and alert routing	Structured logs, correlation IDs, no secrets or SLD payloads, dashboards, retention policy.
Sentinel or approved SIEM	Incident detection and investigation	Ingests identity, WAF, API, DB and admin events; defined use-cases; 24/7 response agreement.
Defender for Cloud	Cloud posture and threat protection	Policy compliance, recommendations, vulnerability assessment and alerts.

PRODUCT / CAPABILITY	WHERE / WHY	IMPLEMENTATION AND SELECTION CRITERIA
SECURITY MONITORING AND INCIDENT DETECTION (CONTINUED)		
External SOC / MDR provider	24/7 response coverage	Contracted alert coverage, response authority, escalation and evidence custody.
SOFTWARE DEVELOPMENT SECURITY		
GitHub Enterprise / Advanced Security	Secure code lifecycle	Private repos, branch rules, secret scanning, code scanning, Dependabot, required reviews and audit.
Semgrep or CodeQL	Static application security testing	Scan every pull request; critical findings block merge; rules validated against the Node / JS stack.
Terraform + Azure Policy	Repeatable environments	Policy-as-code, least privilege, drift detection, change approval, no manual changes in production.
VULNERABILITY MANAGEMENT		
Dependabot / Snyk / equivalent	Software composition analysis	CVE and licence tracking; SBOM per release; patch SLA; pinned, reviewed dependencies.
OWASP ZAP + Burp Suite (professional testers)	DAST and manual testing	Authorised staging tests: tenant breakout, IDOR, workflow abuse, session handling.
BACKUP AND DISASTER RECOVERY		
Backup / PITR + immutable archive	Recover and preserve evidence	Cross-region copy only where the data owner permits; quarterly restore and annual disaster exercise.
GOVERNANCE AND COMPLIANCE		
ServiceNow / Jira / approved ticketing	Changes, risks, incidents, approvals	Alert and approval integration; client segregation; contractual retention.

04

PART 04

RISK & ASSURANCE

Each threat scored before and after the designed controls, and the testable requirements and evidence the client receives before go-live.

9	Risk methodology and register
10	Security requirements and acceptance evidence

SECTION 09

Risk methodology and register

METHOD

Each threat is scored likelihood (1–5) × impact (1–5) twice: **inherent** — with no controls in place — and **residual** — with the designed controls operating. Residual scores are confirmed through the acceptance tests in Section 10.

ASSETS PROTECTED

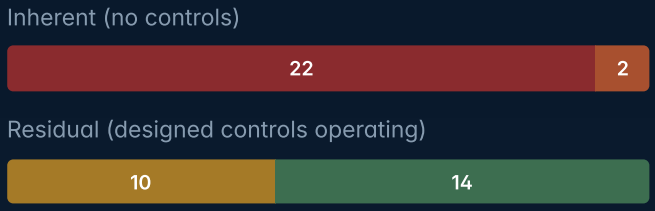
- SLDs and lock mappings
- Permit state and key custody
- Identity and competence records
- Audit evidence
- Availability and client trust

Likelihood (rows) × impact (columns)

	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

Low 1–5 · Moderate 6–10 · High 11–15 · Critical 16–25

REGISTER PROFILE — 24 RISKS



The design reduces all 24 risks from critical or high to moderate or low: 10 moderate and 14 low. No high or critical residual risk remains.

OWNERSHIP

Each risk has a named owner and review date from project kickoff. Residual risk is accepted jointly by the Powertec business owner, the security owner and the relevant client authority — never by the development team alone.

Risk register · R01–R08

"Verified by" cross-references the acceptance requirements in Section 10.

REF	THREAT · CAUSE	INHERENT	DESIGNED CONTROLS	RESIDUAL	VERIFIED BY
R01	**Unauthorised read of drawings / permits** Broken API authorisation	25 CRITICAL	OIDC, server-side policy, private storage, audit	10 MODERATE	SEC-01 · 02 · 06
R02	**Unauthorised PTW cancellation** Actor spoofing; forged request	25 CRITICAL	Verified identity, state machine, dual control, alerts	5 LOW	SEC-01 · 03 · 07
R03	**Cross-tenant data exposure** Missing site filter / BOLA	20 CRITICAL	Tenant / site FK, policy, negative tests, dedicated tier	5 LOW	SEC-02 · 15
R04	**Malicious SLD replacement** Uncontrolled upload / version	20 CRITICAL	Approval, checksums, immutable versions, quarantine	5 LOW	SEC-05
R05	**Incorrect lock-to-apparatus mapping** Human import or drawing interpretation	20 CRITICAL	Two-person engineering verification and reconciliation	10 MODERATE	SEC-03 · 05
R06	**Key allocation collision** Race condition in concurrent issuance	20 CRITICAL	Serializable transaction / unique active constraints	5 LOW	SEC-04
R07	**Credential compromise** Phishing / stolen session	20 CRITICAL	FIDO2, conditional access, session revoke, monitoring	8 MODERATE	SEC-01 · 08
R08	**Insider misuse / excessive privilege** Standing admin or cross-client support	20 CRITICAL	PIM / JIT, least privilege, audit, approvals	8 MODERATE	SEC-02 · 07

Risk register · R09–R16

REF	THREAT · CAUSE	INHERENT	DESIGNED CONTROLS	RESIDUAL	VERIFIED BY
R09	**Ransomware / destructive event** Endpoint or cloud account compromise	20 CRITICAL	EDR, immutable backups, separation, exercises	10 MODERATE	SEC-08 · 09
R10	**Data loss / corruption** Database failure or logical error	20 CRITICAL	Zone-redundant DB, PITR, integrity tests, restore drills	5 LOW	SEC-09
R11	**Cloud misconfiguration** Public blob / exposed DB	20 CRITICAL	Private endpoints, policy-as-code, CSPM, review	5 LOW	SEC-06 · 13
R12	**Supply chain compromise** Malicious package / CI token	20 CRITICAL	SCA, pinning, signed artifacts, OIDC CI, SBOM	8 MODERATE	SEC-13
R13	**Denial of service** Bot flood or regional outage	16 CRITICAL	WAF, limits, capacity, runbooks, DR	8 MODERATE	SEC-08 · 09
R14	**Stale / offline display** Lost connectivity or cached interface	25 CRITICAL	Fail closed, freshness indicator, no offline issuance	5 LOW	SEC-14
R15	**Leaked secrets** Repo, logs, device screenshots	20 CRITICAL	Vault, secret scan, rotation, DLP	8 MODERATE	SEC-06
R16	**Training qualification fraud** Certificate forgery / unapproved role	20 CRITICAL	Server-side results, signed evidence, HR / site approval	8 MODERATE	SEC-12

Risk register · R17–R24

REF	THREAT · CAUSE	INHERENT	DESIGNED CONTROLS	RESIDUAL	VERIFIED BY
R17	**Training-to-operations privilege escalation** Over-trusted integration	20 CRITICAL	Signed scoped assertions, separate admin, authorisation gates	5 LOW	SEC-12
R18	**Compromised mobile device** Unmanaged or lost device	16 CRITICAL	Device policy, short sessions, remote revoke	8 MODERATE	SEC-01
R19	**Unlawful cross-border processing** Unapproved region / subprocessor	15 HIGH	Data map, DPA, region controls, approvals	5 LOW	SEC-11
R20	**Audit log tampering** Administrator with log access	20 CRITICAL	Write-once separate account, cryptographic chaining	5 LOW	SEC-07
R21	**Unsafe use during outage** No verified status or manual procedure	20 CRITICAL	Site-approved fallback, stop issuance, exercises	5 LOW	SEC-14
R22	**Client content reused across tenants** Training template or SLD reuse	20 CRITICAL	Licence tags, classification, publish approval, DLP	5 LOW	SEC-11 · 12
R23	**Unauthorised AI processing** SLDs pasted into AI / chat tools	20 CRITICAL	No AI processing of client data, DLP, contractual restriction	5 LOW	SEC-11
R24	**Privacy / retention failure** Excess staff data or indefinite logs	12 HIGH	Minimisation, retention automation, DSR procedure	4 LOW	SEC-11

SECTION 10

Security requirements and acceptance evidence

VERIFICATION BASELINE — OWASP ASVS 5.0.0

Level 2 across both platforms, the level intended for applications handling sensitive data. Level 3 is applied to authentication, authorisation and audit in Platform A, where permit integrity is safety-relevant. Every requirement is mapped to a test and its evidence.

ID	CONTROL OBJECTIVE	TESTABLE ACCEPTANCE	EVIDENCE
SEC-01	Federated identity, MFA and revocation	Unauthenticated calls return 401; a removed member loses access within the agreed propagation target.	Identity configuration and tests
SEC-02	Site / tenant RBAC / ABAC	Cross-tenant GET / POST / search / export / SSE denied in automated adversarial tests.	Policy and test report
SEC-03	Document lifecycle integrity	Invalid transitions, self-approval and actor spoofing rejected.	Workflow tests
SEC-04	Transactional lock uniqueness	Parallel requests cannot double-allocate a physical key or box.	Concurrency test
SEC-05	SLD provenance	Revision, checksum, approver, owner and effective date recorded for every drawing.	Controlled sample
SEC-06	Secrets and encryption	No production secrets in repository or client; TLS and encryption settings verified.	Scan / config evidence
SEC-07	Audit integrity	Critical actions logged to a separate append-only store with identity and UTC timestamp.	Tamper test
SEC-08	Monitoring	Alert reaches the named on-call responder and creates an incident ticket.	End-to-end drill

Acceptance requirements · SEC-09 – SEC-15

Each requirement is VERIFIED AT ACCEPTANCE by the stated evidence.

ID	CONTROL OBJECTIVE	TESTABLE ACCEPTANCE	EVIDENCE
SEC-09	Backup / recovery	Production-equivalent data restored to an isolated environment within the agreed RTO / RPO.	Restore evidence
SEC-10	Application assurance	OWASP ASVS 5.0 mapping; no unresolved critical / high findings before restricted-data go-live.	Independent test
SEC-11	Privacy / data ownership	Signed data-flow map, DPA, subprocessor approvals, retention and deletion plan.	Client sign-off
SEC-12	Training segregation	Training completion cannot itself grant operational authority; cross-client content inaccessible.	Integration tests
SEC-13	Secure deployment	Protected branch, reviewed PR, signed build, approved release and rollback.	Pipeline logs
SEC-14	Emergency operation	Degraded-mode drill confirms the app never asserts safe isolation when disconnected.	Site exercise
SEC-15	Dedicated tier	Sensitive client tenancy uses an approved independent boundary and access policy.	Architecture review

05

PART 05

INCIDENT RESPONSE & RECOVERY

Severity classification and response targets, the incident operating procedure, ten worst-case scenario playbooks and recovery objectives for each service tier.

11	Incident severity, detection and response
12	Incident management operating procedure
13	Worst-case scenario playbooks
14	Recovery objectives and business continuity

SECTION 11

Incident severity, detection and response

SERVICE TARGETS

Response targets are contracted at onboarding, delivered by staffed 24/7 monitoring and proven in exercises before go-live. Client notification for a SEV-1 occurs immediately on validation — well inside the 24-hour early-warning window that applies to operators under Sweden's Cybersecurity Act.

SEVERITY	EXAMPLE	OPERATIONAL TARGETS (SERVICE TARGET)
SEV-1 Critical	Confirmed restricted SLD exposure, forged live permit, cross-tenant breach, ransomware affecting safety workflows	24/7 alerting; human acknowledgement ≤15 min after alert; incident commander ≤30 min; initial containment decision ≤60 min; client contact immediately after validation.
SEV-2 High	Privileged account takeover, significant suspicious exports, partial production outage	Acknowledge ≤30 min; triage ≤60 min; containment plan ≤2 h.
SEV-3 Moderate	Limited vulnerability or non-critical service impairment	Triage within 1 business day; fix by risk-based SLA.
SEV-4 Low	Informational finding or minor policy deviation	Record, prioritise and address in routine change cycle.

Detection coverage

Signals ingested and alerted on by the monitoring service.

- IdP risky sign-ins
- Impossible travel
- WAF attacks
- API 401 / 403 bursts
- Mass downloads
- Unusual export volume
- Cross-tenant denied queries
- Unapproved SLD revisions
- Lock / permit transition anomalies
- Privilege grants
- CI/CD pipeline changes
- Key-vault reads
- Backup deletion attempts
- EDR detections
- Database error alerts
- Integrity alerts

SECTION 12

Incident management operating procedure

Timeline following a validated SEV-1 alert. SERVICE TARGET

0–15 MIN — SOC / on-call opens the incident record; establishes timestamp and affected organisation / site; freezes destructive routine changes; pages incident commander, engineering lead and security owner through more than one channel.

15–30 MIN — Assesses whether operational safety information may be unreliable. Notifies the client's designated operations contact and site safety authority via the pre-agreed route; recommends suspension of affected electronic issuance pending their decision. Preserves logs and volatile evidence.

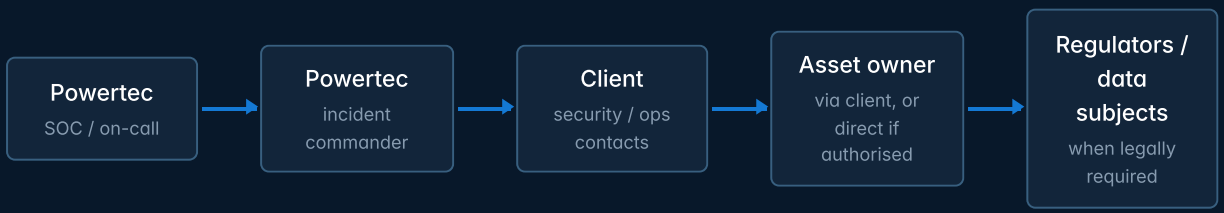
30–60 MIN — Contains with the least disruptive safe measure: revoke sessions / tokens, disable the affected integration, restrict tenant or API, isolate the workload, stop downloads, switch to read-only or unavailable banner. The client controls physical site operations.

1–4 HOURS — Identifies attack path and data categories; verifies integrity of drawings, lock mappings and documents against the immutable audit; estimates exposure; initiates contractual notifications; maintains evidence chain.

4–24 HOURS — Eradicates the cause, rotates credentials, rebuilds from a known-good signed release, assesses cross-tenant exposure, issues factual stakeholder updates and executes the approved recovery plan.

24–72+ HOURS — Supports the data owner's regulator and privacy notifications with counsel; tests the recovered environment; obtains safety, technical and security approval before workflows resume; publishes incident report and corrective-action register.

COMMUNICATION CHAIN



Statutory clocks (GDPR 72 hours; Swedish Cybersecurity Act 24 h / 72 h / 1 month) run from the operator's awareness; Powertec's immediate notification gives the client the full window.

SECTION 13

Worst-case scenario playbooks

PLAYBOOK STRUCTURE

Each scenario defines detection signals, first-hour containment and recovery verification. **Investigation** (evidence preservation, attack-path and root-cause analysis), **damage limitation**, **notification** and **post-incident assurance** follow the operating procedure and communication chain in Section 12. Every playbook is rehearsed in tabletop exercises.

01 SCENARIO A — Public exposure of site SLDs

DETECTION	Unusual download spikes, anonymous-access test, DLP alert or client report
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Disable affected object access and external routes; revoke signed URLs and tokens; preserve WAF / storage access logs; identify every exposed revision and recipient; notify the client and the approved asset-owner route; never delete evidence.
RECOVERY & VERIFICATION	Validate the access-control repair, scan for other public objects, rotate affected credentials, review indexing / caches, document disclosure scope.

02 SCENARIO B — Forged cancellation of an active PTW

DETECTION	Audit shows unapproved actor, impossible sequence or operator dispute
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Treat application state as unreliable; freeze electronic cancellations / issuance; alert site SAP / AP authority; reconcile physical documents, keys and boxes; revoke actor and isolate API.
RECOVERY & VERIFICATION	Reconstruct from signed evidence; approve corrections through the controlled process; independent safety and security sign-off.

03 SCENARIO C — Cross-tenant leak to another contractor

DETECTION	Customer sees a foreign site record, or a negative tenant test fails
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Disable affected endpoint / export / search; suspend involved tenant scopes; preserve query logs and access events; identify all potentially exposed clients.
RECOVERY & VERIFICATION	Repair authorisation at API and DB, re-test all routes, commission independent review, notify affected parties under contract.

04 SCENARIO D — Ransomware / database destruction

DETECTION	EDR or cloud alert, missing DB objects, bulk deletion
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Isolate compromised principals / workloads; protect immutable backups; suspend app transactions; communicate the manual site procedure via authorised operations.
RECOVERY & VERIFICATION	Rebuild a clean environment, restore to point in time, verify document / lock consistency and audit continuity before go-live.

05 SCENARIO E — SLD malicious substitution

DETECTION	Checksum mismatch, unexpected revision approval, operator challenge
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Quarantine the revision; block use and issuance linked to it; notify engineering document controller and SAP; identify affected permits.
RECOVERY & VERIFICATION	Restore last approved version; independently re-verify apparatus mapping; examine the upload and approval chain.

06 SCENARIO F
Identity provider or internet outage

DETECTION	Synthetic monitoring fails, token errors, users cannot validate status
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Display outage and unverified status; block new electronic safety documents; direct users to the client-approved contingency procedure; never show cached “live” status.
RECOVERY & VERIFICATION	Reconcile outstanding documents and physical custody before re-enabling.

07 SCENARIO G
Compromised training administrator

DETECTION	Bulk pass grades, forged certificates, unexpected role grants
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Suspend training-to-operations sync; revoke accounts / tokens; quarantine suspect competence records; notify the site authorisation owner.
RECOVERY & VERIFICATION	Revalidate competence evidence and independent appointments; review all recent authorisation changes.

08 SCENARIO H
CI/CD supply-chain takeover

DETECTION	Unexpected deployment, new package, pipeline credential anomaly
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Disable deployments; revoke CI credentials; block release; isolate build artifacts; check production hashes.
RECOVERY & VERIFICATION	Rebuild from verified source, rotate secrets, review SBOM and dependencies, independent approval to resume.

09 SCENARIO I — Lost device

DETECTION	Device report, suspicious mobile token use
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Revoke sessions and device trust; remote wipe if managed; investigate exports and browser storage; notify client as required.
RECOVERY & VERIFICATION	Confirm no sensitive offline storage; enforce conditional access.

10 SCENARIO J — Backup compromise / malicious deletion

DETECTION	Backup vault change alert, missing recovery points
INITIAL RESPONSE & CONTAINMENT FIRST HOUR	Lock backup administration; preserve separate copies; disable the compromised privileged identity; invoke DR command.
RECOVERY & VERIFICATION	Restore in an isolated account, validate audit and data, tighten backup privilege separation.

SECTION 14

Recovery objectives and business continuity

TIER	RTO	RPO	FALLBACK
Safety document / lock register core	4 hours	15 minutes log backups every ≤5 min; zero loss on zone failover	Stop electronic issuance; site-approved physical / manual process only.
SLD access	8 hours	Latest approved revision / no unapproved loss	Approved controlled offline drawings only if the client permits.
Training site	24 hours	4 hours	Reschedule training; no inference of current authorisation.
Security logs	Continuity to independently retained archive	Near-real-time streaming	Evidence preservation and incident escalation.

RTO
Maximum time to restore service.

RPO
Maximum recoverable data gap.

SAFETY GATE Restoration is complete only after safety data reconciliation: a restored database is not returned to service on technical recovery alone.

Continuity testing programme



- Backup keys and admin privileges separated from application operators; immutable storage for critical evidence; replication only where the data owner permits.
- Restore tests cover a live / cancelled document chain, unique lock allocations, current SLD revision and training authority linkage — not only database connectivity.

06

PART 06

GOVERNANCE, COMPLIANCE & DELIVERY

Legal and standards obligations, the delivery programme, accountability and cadence, supplier controls, the client assurance pack and go-live gates.

15	Legal, contractual and standards obligations
16	Delivery programme
17	Governance and operating cadence
18	Supplier and subcontractor controls
19	Client assurance pack
20	Go-live acceptance gates
21	Standards and reference sources

SECTION 15

Legal, contractual and standards obligations

Client supplier-assurance programmes

Hyperscale asset owners operate formal supplier security and privacy programmes that flow down to subcontractors: typically annual self-attestation, independent assurance for SaaS suppliers by assessment or an ISO/IEC 27001 certificate covering the contracted service, and fixed response deadlines. The platforms are designed to meet that profile. Neither platform applies AI to client data, avoiding the additional assurance AI systems attract.

Swedish Cybersecurity Act (cybersäkerhetslagen 2025:1506)

In force 15 January 2026, implementing NIS2. Operators report significant incidents with a 24-hour early warning, 72-hour notification and one-month final report. Security duties extend through suppliers to sub-suppliers. PTS supervises digital infrastructure and ICT service management. Fines reach €10m or 2% of global turnover for essential entities.

UK GDPR / EU GDPR

Personnel and training records are personal data. Roles, lawful basis, DPA, transfers, retention and breach duties are fixed per client. Supervisory-authority notification is due within 72 hours of awareness where criteria are met.

ISO/IEC 27001:2022 and 27701

ISMS aligned to ISO/IEC 27001:2022 (93 Annex A controls) with ISO/IEC 27701 privacy mapping. Certification, where required, is evidenced by an accredited certificate.

NIST CSF 2.0 / SP 800-61r3

Govern, Identify, Protect, Detect, Respond and Recover structure the programme; SP 800-61 Rev. 3 (April 2025) frames the incident response lifecycle and exercises.

OWASP ASVS 5.0.0

Testable requirements baseline: Level 2 throughout, Level 3 for Platform A authentication, authorisation and audit.

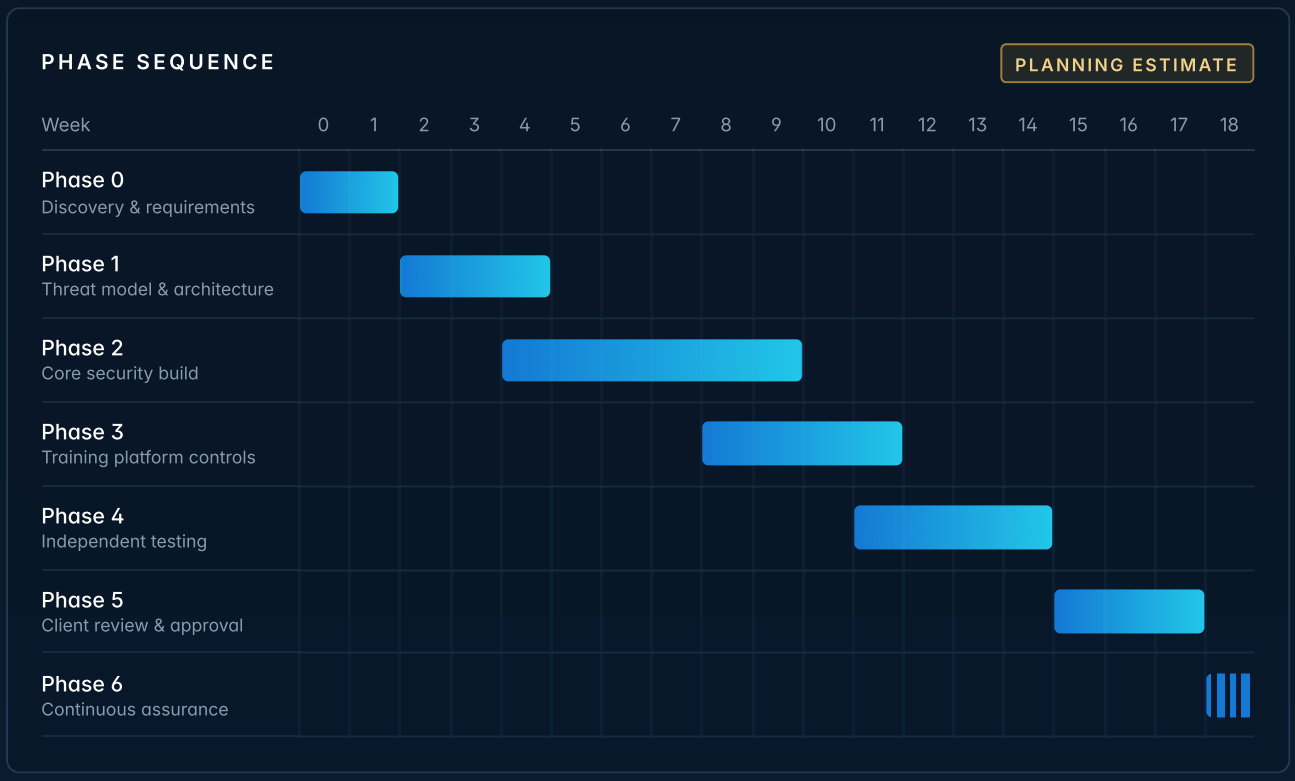
Electrical safety and evidential validity

Client and asset-owner safety rules, local legislation, authorised document workflows and electronic signature requirements are configured per site. Training completion never equals appointment; a database state never equals proven dead apparatus.

SECTION 16

Delivery programme

Security is built alongside the product, and every security workstream is a release gate.



PHASE	ENGINEERING AND SECURITY ACTIVITY	EXIT EVIDENCE (ACCEPTANCE GATE)
Phase 0 Weeks 0–2	Confirm scope; inventory platform components and hosting; name owners; collect client and asset-owner contractual security requirements; approve classification.	Signed scope, asset / data map, issue register, client engagement plan.
Phase 1 Weeks 2–5	Threat model, architecture decision records, tenant model, site roles, identity design, safety workflow requirements.	Approved target architecture, controls matrix, data-flow diagrams.
Phase 2 Weeks 4–10	Build SSO, RBAC, private storage, DB transaction model, secure upload, document integrity, CI/CD, logging.	Hardened staging environment; unit and integration tests.

Phase activities and exit evidence · continued

PHASE	ENGINEERING AND SECURITY ACTIVITY	EXIT EVIDENCE (ACCEPTANCE GATE)
Phase 3 Weeks 8–12	Training-platform controls, signed competence API, content isolation, privacy and retention, client-specific packaging.	Integrated staging with tenant negative tests.
Phase 4 Weeks 11–15	Independent penetration test, approved red-team scenarios, remediation of high findings, DR and incident exercises.	Signed test reports, remediation evidence, recovery results.
Phase 5 Weeks 15–18	Client review; asset-owner data and security review via the approved channel; legal agreements; deployment and operating runbooks.	Conditional go-live approval or recorded blockers.
Phase 6 Ongoing	Monthly vulnerability review; quarterly access and restore reviews; annual independent test and tabletop; per-client recertification.	Security scorecard, risk updates and audit package.

Durations are planning estimates, confirmed with the client at Phase 0 against staffing, procurement and review schedules.

SECTION 17

Governance and operating cadence

ROLE	ACCOUNTABILITY
Powertec business owner	Funding, risk appetite, contracts, release approval, supplier oversight.
Powertec security lead / external vCISO	Risk register, architecture, policy, audit, incident command, assurance evidence.
Engineering lead / development team	Secure coding, remediation, automated tests, CI/CD, architecture implementation.
Data protection lead / counsel	Privacy roles, DPAs, transfer assessments, notification advice.
Client sponsor + security owner	Contractual requirements, subcontractor approval, operational integration and escalation.
Asset owner / security (via approved channel)	Authorise site information, deployment model and assurance acceptance.
Site SAP / AP authority	Validate safety rules, drawing-to-lock mapping, permitted workflow and outage fallback.
Independent assessor	Penetration test and unbiased verification; cannot approve client safety operation.

Operating cadence

WEEKLY
Security-engineering meeting during build

FORTNIGHTLY
Risk review

MONTHLY
Executive steering

PER RELEASE
Evidence review

QUARTERLY
Access and restore checks

ANNUAL
Full threat model and assurance refresh

TRACEABILITY Every control has an owner, implementation ticket, test case and evidence link.

SECTION 18

Supplier and subcontractor controls

SUPPLIER REGISTER

Every hosting, identity, telemetry, email, support, analytics, payment and development provider is registered with its data categories, location, subcontractors, contract terms, incident-notice period and exit provisions — the evidence base for client supplier-assurance and Swedish Cybersecurity Act supply-chain obligations.

RESTRICTED ENGINEERING PAGES

No analytics, advertising pixels, third-party fonts or telemetry SDKs. All assets are self-hosted and third-party embeds are blocked.

AI SERVICES

Site drawings, operational records and procedure-derived training are never processed by cloud AI services without the client's written authorisation.

EXIT PORTABILITY

Tenant data export, document provenance, log evidence, backups, key rotation, deprovisioning and independent deletion confirmation.

SECTION 19

Client assurance pack

Evidence delivered to the client for review before go-live and refreshed annually.

ARCHITECTURE

Architecture and data-flow diagrams for both deployment tiers and the cross-platform interface.

RESPONSIBILITY

Security responsibility matrix across Powertec, client, asset owner, cloud vendor and site authority.

RISK

Risk register with owner, inherent / residual score, acceptance and review dates.

IDENTITY

Identity / role matrix for CP, AP, SAP, training assessor, document controller, auditor, support and platform admin.

TESTING

OWASP ASVS 5.0 control mapping with test results, SBOM, vulnerability and penetration-test summary.

SLD GOVERNANCE

Sample approval, revision, watermark, retention, download logs and authorised-use evidence.

RESPONSE & RECOVERY

Incident response plan, notification contacts, tabletop results, BCP / DR plan and restore results.

CONTRACTUAL

DPA / subprocessor schedule, data residency statement, retention policy, cyber insurance and supplier-assurance questionnaire responses.

Live assurance demonstration

Run on synthetic data, so no client information is used, the demonstration shows:

- Blocked cross-tenant access
- Immediate access revocation
- Audit trace
- Two-person approval
- Controlled SLD replacement
- Offline fail-safe

SECTION 20

Go-live acceptance gates

GATE	REQUIREMENT	EVIDENCE
G1 · DESIGN	Classification, data map and asset-owner approval path agreed with the client; supplier security requirements captured.	Signed scope and named approval contacts.
G1 · DESIGN	Threat model and target architecture approved for both platforms.	Approved architecture and controls matrix.
G2 · BUILD	Authenticated, tenant-scoped transactional backend with workflow state machines.	Independent auth, tenant and concurrency tests.
G2 · BUILD	SLD ingestion approval, immutable revisions and verified apparatus mapping.	Engineering and security sign-off.
G3 · OPERATE	24/7 SEV-1 response capability in place before any restricted deployment.	Alert-to-human exercise passed.
G4 · ASSURE	Independent penetration test, remediation and restore exercise.	No unaccepted high / critical risk.
GO	Client and asset-owner approvals, contracts, tests and safety acceptance recorded.	Written deployment authorisation.

PATH TO DEPLOYMENT AUTHORISATION



SECTION 21

Standards and reference sources

01 Swedish Cybersecurity Act in force — Deloitte Sweden
https://www.deloitte.com/se/sv/services/legal/perspectives/nis2-now-in-force.html

02 New Cybersecurity Act, NIS2 in Swedish law — Lindahl
https://www.lindahl.se/en/expertise/national-security-trade-control/new-cybersecurity-act-implementation-of-the-nis2-directive-in-swedish-law/

03 Verizon 2025 Data Breach Investigations Report
https://www.verizon.com/about/news/2025-data-breach-investigations-report

04 OWASP ASVS 5.0
https://asvs.owasp.org/

05 NIST SP 800-61 Revision 3
https://csrc.nist.gov/pubs/sp/800/61/r3/final

06 NIST Cybersecurity Framework 2.0
https://www.nist.gov/cyberframework

07 UK ICO personal data breach guidance
https://ico.org.uk/for-organisations/report-a-breach/personal-data-breach/

BACK TO CONTENTS

ASSURANCE COMMITMENT

Every control independently verified.
No client data before written acceptance.

Each requirement in this specification is tested and evidenced, and is presented to the client in the assurance pack before go-live. Production use begins only on the client's written deployment authorisation.

VERSION 3.0 | OCTOBER 2026